

Domande di Sicurezza, divise per capitolo

(1) Introduzione alla sicurezza

- Come si affronta un'attacco?
- Cosa è una vulnerabilità?
- Cosa è un exploit?
- Cosa è un attacco?
- Cosa è una BotNet?
- Cosa è il cryptojacking?

(2) Sistema Sicuro

- Quali sono le proprietà di un sistema sicuro?
- Perché un sistema sicuro non può essere garantito?
- Quali sono alcune proprietà che dovrebbero avere le applicazioni di un sistema sicuro?
- Cosa sono i Principals e i Privilegi?
- Cosa è la Repudiation?
- Quali sono le tre regole auree?
- Cos'è l'Autenticazione?
- Come garantisco l'Autenticazione?
- Cos'è l'auditing?
- Cos'è l'accountability
- Cos'è l'autorizzazione?
- Qual'è la differenza tra Confidentiality e Privacy?
- Cosa sono le Security Policy?
- Cosa è una minaccia?
- Di che tipo può essere una minaccia?
- Cos'è il CVE?

(3) Rischio

- Cosa è il rischio?
- Cosa significa approccio risk-based?
- Cos'è il Risk Assesment?
- Qual'è la formula per il calcolo del rischio?
- Cosa sono l'ALE e la Risk Rating Matrix?
- Cosa significa Risk Management?
- Nell'ambito di ISO27001 cosa vuol dire considerare la cybersecurity come un rischio?
- Cosa sono Adversary Modeling e Threat Modeling?
- Cosa è lo STRIDE? Quali sono le sue categorie?
- Cos'è il Penetration Testing? Quanti e quali tipi ne esistono?

- Cosa è una superficie di attacco? Quali sono le più comuni?

(4) Modelli di Accesso

- Cosa è il Reference Monitor?
- Cos'è la Controlled Invocation?
- Come funziona il “The Model” degli accessi?
- Come si definiscono le fasi di Identificazione, Enrollment ed Autenticazione?
- Come funzionano le password? Dove sono salvate? Vantaggi e svantaggi
- Quali sono alcune strategie per indovinare le password?
- Quali meccanismi alternativi alle password ci sono? Cosa è il multifactor authentication?
- Quali sono le cointroindicazioni del multifactor authentication?
- Cosa sono le OTP?
- Come funziona la Biometria?
- Come funziona l'OAuth?
- Come funziona il SSO?

(5) Unix Access Control

- Quali sono i modelli di Access Control più diffusi?
- In quale caso utilizzo uno o l'altro?
- Cosa è la ACM?
- Cosa è e come funziona la ACL?
- Cosa è e come funziona la C-List?
- Differenze tra ACL e C-List?
- Come funziona il controllo degli accessi in UNIX?
- Chi è il Superuser e cosa può fare?
- Come viene determinato l'UID per ogni utente?
- Come vengono generati i processi in Linux?
- Che permessi hanno /etc/passwd ed /etc/shadow?
- Perché fare un bruteforce su shadow invece di cambiare password?
- Come funziona l'hashing di una password ed il salt? Quali sono gli algoritmi più usati?
- Cos'è e come funziona l'UGO Permission Model?
- Cos'è la Privilege Escalation?
- Cosa sono RUID ed EUID?
- Cos'è il SETUID?
- Come si implementa?
- Se un programma con SETUID fa fork che UID ha il figlio?
- Come imposto SETUID tramite comandi?

(6) Auditing e Log

- Cosa sono Detection e Protection?
- Cosa sono i file di log?
- Dove vengono salvati?
- Cosa devono garantire i file di log?
- Come si chiamano in Windows i file di log?
- Come si può evitare l'utente root cancelli i file di log?
- Quali sono le problematiche dei file di log?
- Chi fa l'analisi dei log?
- Come si accorge un sistemista di una privilege escalation?
- Come può essere fatta la detection dei log?
- Cosa è un IDS?
- Cosa è un SIEM?

(7) Exploitation e Software Security

- Qual'è la differenza tra Hard link e Soft link?
- Cos'è TOCTOU?
- Cos'è una Race Condition?
- Quale proprietà uso per evitare le RACE Condition o TOCTOU?
- Cos'è lo Stack? Cosa punta al suo ultimo elemento?
- Cos'è e come è fatto lo Stack Frame? Che registri ha?
- Cosa sono CALL e RET? Cosa differenzia CALL da JUMP?
- Come funziona la tecnica di Smashing The Stack?
- Come funziona un Buffer Overflow?
- Quali sono le più comuni contromisure ai Buffer Overflow?
- Come funziona l'ASLR? Quali parti di memoria può randomizzare?
- Come funziona lo Stack Canary?
- Cosa è l'NX?
- Che tecnica posso usare per aggirare l'NX?
- Cosa è la DEP?
- Cos'è un Nop Sled?
- Che conoscenze devo avere oggi per fare un Overflow?
- Cos'è un Integer Overflow? Come lo si evita?

(8) Crittografia

- Cosa garantisce la Crittografia? A cosa serve?
- Quali problemi risolve? Cosa permette?
- Quali nuovi problemi introduce?
- Gli algoritmi di crittazione sono noti? Qual'è l'inverso di ciò?
- Quali sono i due tipi di crittografia?
- Come funziona la Crittografia Simmetrica? Quali metodi di crittazione usa?

- Come funziona lo Stream Cipher? Quali sono alcuni esempi?
- Come funziona il Block Cipher? Quali sono alcuni esempi?
- Quali sono i vantaggi e gli svantaggi della Crittografia Asimmetrica?
- Come funziona la Crittografia Asimmetrica? Cosa è la Hybrid Encryption?
- Come funziona RSA? Su quale problema matematico si basa?
- Come funzionano le Firme Digitali? Cosa garantiscono?
- Come funzionano le Funzioni Hash? Che proprietà hanno?
- Come avviene la Firma Digitale tramite Hash?
- Cosa è il MAC? Cosa garantisce?
- Come è implementato a livello Hardware il MAC?
- Cosa è una SystemCall? Come Avviene un Interrupt Hardware?
- Cosa sono CPL e DPL?
- Cos'è l'HMAL?
- Cosa sono i certificati? Cosa è la CA?
- Cosa è la PKI?
- Cosa sono i certificati Self-Signed?
- Come fai a fidarti di Google nell'ambito dei certificati?
- Come posso evitare un attacco MITM grazie ai certificati?

(9) Malware

- Cos'è un malware?
- Qual'è la differenza tra un virus ed un worm? Quale è più facile da realizzare?
- Quali sono le fasi di un virus?
- Cosa è il code-signing?
- Posso affermare che un sistema non è infetto?
- Dove si possono nascondere i virus?
- Quali sono alcune tecniche utilizzate da virus per non essere rilevati?
- Qual'è la differenza tra virus polimorfi e metamorfi?
- Cosa è un resident malware?
- Che tecniche usano gli antivirus per trovare e neutralizzare i virus? E per quelli particolarmente complessi?
- Come fa un virus a non essere rilevato in una macchina virtuale?
- Come sono chiamati gli antivirus moderni? Cosa fanno?
- Cosa sono i Trojan?
- Cosa sono le Backdoors?
- Cosa sono i Rootkits?
- Cosa è un Auto-Rooter?
- Cosa sono i Ransomware?
- Cosa sono le Botnets?
- Cosa è una logic bomb?
- Cosa è il Social Engineering?

(10) La Rete

- Cosa è la rete? Cosa sono una LAN e una WAN? Cosa è un router?
- Cosa è il Packet Switching?
- Cosa è un MAC ADDRESS?
- Quali sono i protocolli connection-oriented?
- Come funziona il TCP? Come si stabilisce una connessione?
- Come viene scelto in che modo inviare un pacchetto?
- Cosa contengono i pacchetti?
- Cos'è una ARP Request?
- Cos'è il Protocollo ICMP?

(11) Web Security

- Cos'è un DNS e come funziona? Come è formato un URL?
- Cos'è HTML?
- Cos'è HTTP? Come funziona? Cos'è un HTTP Proxy?
- Cos'è un DOM?
- Cosa sono i Cookie? Che attributi hanno? A cosa servono?
- Quali sono le vulnerabilità dei Cookie?
- Cos'è la SOP?
- Cosa è un CSRF? Cosa sfrutta? Come si combatte?
- Cosa è XSS?
- Come funziona Stored XSS? Come lo evito?
- Come funziona Reflected XSS? Come lo evito?
- Cosa è un SQL Injection? Come si può svolgere?
- Quali sono le contromisure contro l'SQL Injection?

(12) Network Security

- Quali tipi di attacchi esistono?
- Cos'è lo Spoofing? E il packet sniffing? Come lo ostacolo?
- Cos'è un attacco DOS? Quali tipi ne esistono?
- In cosa consiste il Ping Of Death?
- In cosa consiste lo Smurf Attack?
- In cosa consiste un Land Attack?
- In cosa consiste un Syn Flooding?
- Cosa è l'Ingress Filtering?
- In cosa consiste il DNS Pharming?
- Cos'è e come funziona ARP?
- In cosa consiste l'ARP Spoofing?
- In cosa consiste l'ARP Poisoning?
- In cosa consiste l'ARP Cache Poisoning?
- Quale vulnerabilità sfrutta l'ARP poisoning?
- Cosa consente di fare l'ARP Poisoning? Che limiti ha?

- In cosa consiste il MITM?
- Come potrei interpormi tra un cliente ed una banca?
- In cosa consiste il TCP Hijacking?
- Cosa è stato e come funzionava il Mitnick attack?

(13) Crittografia Online e Sicurezza

- Quali sono i vari livelli di cifratura e in cosa consistono?
- Cos'è e come funziona IPSEC?
- Quali servizi offre IPSEC e come sono implementati?
- Cosa sono SA e SAD?
- Cos'è HTTPS? Che cosa utilizza? Cosa permette questo servizio? Che algoritmi usa?
- Come creo un canale TLS Client-Server? Come funziona l'Handshake?
- Cos'è una Cipher Suite?
- Quali sono le differenze tra IPSEC e TLS? Possono andare insieme?
- Cos'è una PSK?
- Come funziona la Server Authentication?
- Cos'è e come funziona il Diffie-Hellman Key Exchange?
- Cos'è la E2E Encryption? Quali protocolli utilizza?
- Come funziona MTProto?
- Come funziona Signal?
- Quali sono le differenze tra Signal e MTProto?
- Come funziona l'autenticazione di una carta di credito?
- Cos'è WEP? Perché oggi non è sicuro?

(14) Firewall

- Cos'è un Cyber Security Framework? Quali sono i suoi punti?
- Cos'è un Firewall? Come funziona?
- Quali sono le limitazioni dei Firewall?
- Quali tipi di Firewall esistono?
- Cos'è il NAT? È una misura di sicurezza?
- Cosa sono la Deny Rule e la Allow Rule?
- Come funzionano i Packet Filtering Firewall?
- Come funzionano i Packet Proxy Firewall?
- Qual'è meglio tra Packet Filtering e Proxy? Perché?
- Cos'è un NGFW? Quali capacità ha?
- Cos'è un personal Firewall? E un internet Firewall?
- Cos'è la DMZ?
- Cosa sono i Bastion Hosts?

(15) IDF, SIEM e Privacy

- Cos'è un IDS? E un IPS?
- Quanti e quali tipi di IDF e metodi di rilevazione esistono?
- Cos'è un SIEM?
- Cosa sono SOC e CSOC? Cosa sono i CERTS?
- Cos'è un Honeypot?
- Perché la privacy ha valore? Cos'è la Digital-Privacy?
- Quali dati personali vengono venduti online? Cosa sono i dati PIL e Non-PIL?
- Perché il Privacy-Gap è un problema? Quali sono tipici attacchi che minacciano la Privacy?
- In cosa consiste il furto d'identità? E l'user profiling?
- Cosa vuol dire Società della sorveglianza?
- Cos'è un Data Breach?
- Cos'è il GDPR?
- Quali sono i punti fondamentali del GDPR?
- Cosa includono i personal data? Cos'è il consenso informato?
- Cosa sono le PET? Cosa garantiscono?
- Cosa permettono di fare le PET? I dati cifrati garantiscono la Privacy?

(BONUS) Criptovalute

- BTC garantisce l'anonimato?
- Come implementa i soldi? Ha un entità centrale?
- Cos'è la Block-Chain?
- Perché la Block-Chain è così diffusa?
- Cosa sono i Nodes?
- Cos'è la POW? Cosa vuol dire minare un blocco?
- BTC è efficiente come sistema?

LABORATORIO

- Cos'è un file ELF?
- Cos'è uno shellcode?
- Cos'è un codice position independent?
- Qual'è la differenza tra shellcode ed eseguibile?
- Qual'è la differenza tra formato oggetto ed eseguibile?
- Cos'è e come funziona GDB?
- Che differenza c'è tra un linker statico e dinamico?
- Cosa sono GOT e PLT?
- Da cosa è data la sicurezza di PKI?
- Cos'è PGP?
- Cosa sono Trust e Validity in PGP?
- Cos'è GPG? A cosa serve?

- Cos'è il Web Of Trust? Che differenza ha con la CA?
- Cos'è un Rainbow Table Attack?
- Cos'è John the ripper? A cosa serve?
- Cos'è TOR? Da cosa è formato?
- Quali sono i protocolli di connessione usati da TOR?
- L'ultimo nodo può leggere il contenuto?
- Come creo un circuito TOR?
- Come funziona l'Onion Routing?
- Come è fatta la struttura dei nodi?
- Come avviene una connessione TOR?
- Quali sono gli svantaggi di TOR?
- Cos'è Metasploitable? E Armitage?
- Cos'è il Port Scanning?
- Cos'è Traceroute?
- Cos'è Nmap?
- Come evito di essere rilevato mentre utilizzo Nmap?
- Cos'è Iptables?
- Cos'è SQLMAP?